

(d) Mapeo detallado de preguntas a requisitos normativos ISO/IEC 42001

Bloque/Pregunta	Tema resumido	Requisito ISO/IEC 42001 relacionado	Tipo de requisito
1.1	Política de IA aprobada	Cláusula 5 (Liderazgo), 5.2 Política	Gobernanza
1.2	Alcance del AIMS	Cláusula 4 (Contexto), 4.3 Determinar el alcance del AIMS	Contexto y alcance
1.3	Órganos de gobierno	Cláusula 5 (Liderazgo), 5.1 Compromiso de la dirección	Gobernanza
1.4	Revisión de objetivos y métricas	Cláusula 9 (Evaluación del desempeño), 9.3 Revisión por la dirección	Evaluación
1.5	Integración en cuadros de mando	Cláusula 6 (Planificación), 6.2 Objetivos del AIMS	Planificación
2.1	Inventario de sistemas de IA	Anexo A: controles de recursos y gestión de activos de IA	Operación
2.2	Clasificación de criticidad	Cláusula 6 (Planificación de riesgos), Anexo A (gestión de riesgos de IA)	Riesgos
2.3	Fichas técnicas/model cards	Anexo A (documentación y transparencia de sistemas de IA)	Documentación
2.4	Cobertura de inventario	Cláusula 7 (Apoyo) y 8 (Operación)	Operación
3.1	Análisis de riesgos específico de IA	Cláusula 6.1 Acciones para tratar riesgos y oportunidades	Riesgos
3.2	Revisión de riesgos	Cláusula 9.1 Monitorización, medición y análisis	Evaluación
3.3	Amenazas específicas de IA	Anexo A (seguridad y abuso de sistemas de IA)	Seguridad
3.4	Riesgo residual documentado	Cláusula 6.1 y 6.2, gestión de riesgos residual	Riesgos
3.5	Integración en mapa global de riesgos	Cláusula 4.1 y 4.2 (Contexto) y 6 (Planificación)	Integración

4.1	Clasificación de datos de IA	Anexo A (gestión de datos de IA), alineado con ISO 27001	Seguridad de la información
4.2	Anonimización/pseudonimización	Anexo A (privacidad y datos personales en IA)	Privacidad
4.3	Controles de acceso a datos	Cláusula 7 (Apoyo) y Anexo A (acceso y control)	Seguridad
4.4	Logging de accesos a datos	Cláusula 9.1 (monitorización) y Anexo A (registro de actividades)	Monitorización
4.5	Retención y borrado de datos	Anexo A (ciclo de vida de datos de IA)	Cumplimiento
5.1	Desarrollo seguro de IA	Cláusula 8 (Operación) y Anexo A (ciclo de vida de sistemas de IA)	Operación
5.2	Pruebas de seguridad de modelos	Cláusula 8, 9.1 y Anexo A (pruebas y validación)	Seguridad
5.3	Gestión de cambios y versiones	Cláusula 8 (control operacional)	Operación
5.4	Criterios go/no-go	Cláusula 8.1 Planificación y control operacional	Operación
5.5	Registro de incidentes de modelos	Cláusula 9.1 y Anexo A (incidentes y anomalías)	Monitorización
6.1	Grado de monitorización	Cláusula 9.1 (monitorización y medición)	Evaluación
6.2	KPIs de ciberseguridad de IA	Cláusula 9.1, 9.2, Anexo A (indicadores)	Métricas
6.3	Frecuencia de revisión de KPIs	Cláusula 9.3 Revisión por la dirección	Evaluación
6.4	Gestión de deriva como riesgo	Anexo A (monitorización post-deploy y drift)	Seguridad
6.5	Telemetría de intentos de abuso	Anexo A (detección de abuso y ataques)	Seguridad
7.1	Procedimientos de incidentes IA	Cláusula 8.7 Gestión de incidentes	Incidentes
7.2	Medición de tiempos de respuesta	Cláusula 9.1 (medición de desempeño)	Métricas
7.3	Simulacros y ejercicios	Cláusula 8.7 y 10 (mejora)	Preparación

7.4	Lecciones aprendidas	Cláusula 10 Mejora continua	Mejora
7.5	Coordinación IA–ciberseguridad	Cláusula 7 (competencia y comunicación)	Organización
8.1	Evaluación de proveedores de IA	Cláusula 8.1, Anexo A (relación con terceros)	Terceros
8.2	Cláusulas contractuales de seguridad	Anexo A (contratos y proveedores)	Cumplimiento
8.3	Monitorización de incidentes de terceros	Cláusula 9.1 y Anexo A	Monitorización
8.4	Planes de contingencia para IA externa	Cláusula 8.2 Preparación y respuesta	Continuidad
8.5	Gestión de cadena de suministro de IA	Anexo A (supply chain de IA)	Terceros
9.1	Formación en IA segura	Cláusula 7.2 Competencia	Personas
9.2	Sensibilización de usuarios	Cláusula 7.3 Toma de conciencia	Personas
9.3	Roles y responsabilidades de IA	Cláusula 5.3 Roles, responsabilidades y autoridades	Gobernanza
9.4	Cultura de reporte de problemas	Cláusula 7.4 Comunicación	Cultura
9.5	Nivel global de madurez	Cláusula 9 y 10 (evaluación y mejora)	Global
10.1	Documentación del IGM	Cláusula 9.1, 9.2 (medición y análisis)	Métricas
10.2	Cuantificación de impacto económico	Cláusula 9 (evaluación) y 10 (mejora basada en evidencias)	Riesgos
10.3	Análisis de ROI	Cláusula 6.2 Objetivos y planificación	Estrategia
10.4	Uso de indicadores en decisiones	Cláusula 5 y 9 (liderazgo y revisión basada en datos)	Gobernanza
10.5	Motivación para madurez ISO 42001	Cláusula 4 (contexto) y 5 (liderazgo)	Contexto